Risk Priority Matrix & Top 5 Recommendations

In simple terms: We tested our AI customer-service assistant by trying to break its security and identify five weaknesses. The chart below ranks them based on how easy they are to exploit (left to right) and the level of damage they could cause to the business (bottom to top).

We then applied five security fixes and tested the assistant again. The results showed a drop in the overall attack success rate from around 88% to 0%. This page highlights the risks identified before the fixes were applied, while the next page outlines the investments needed to maintain these improvements and prevent the same issues from returning.

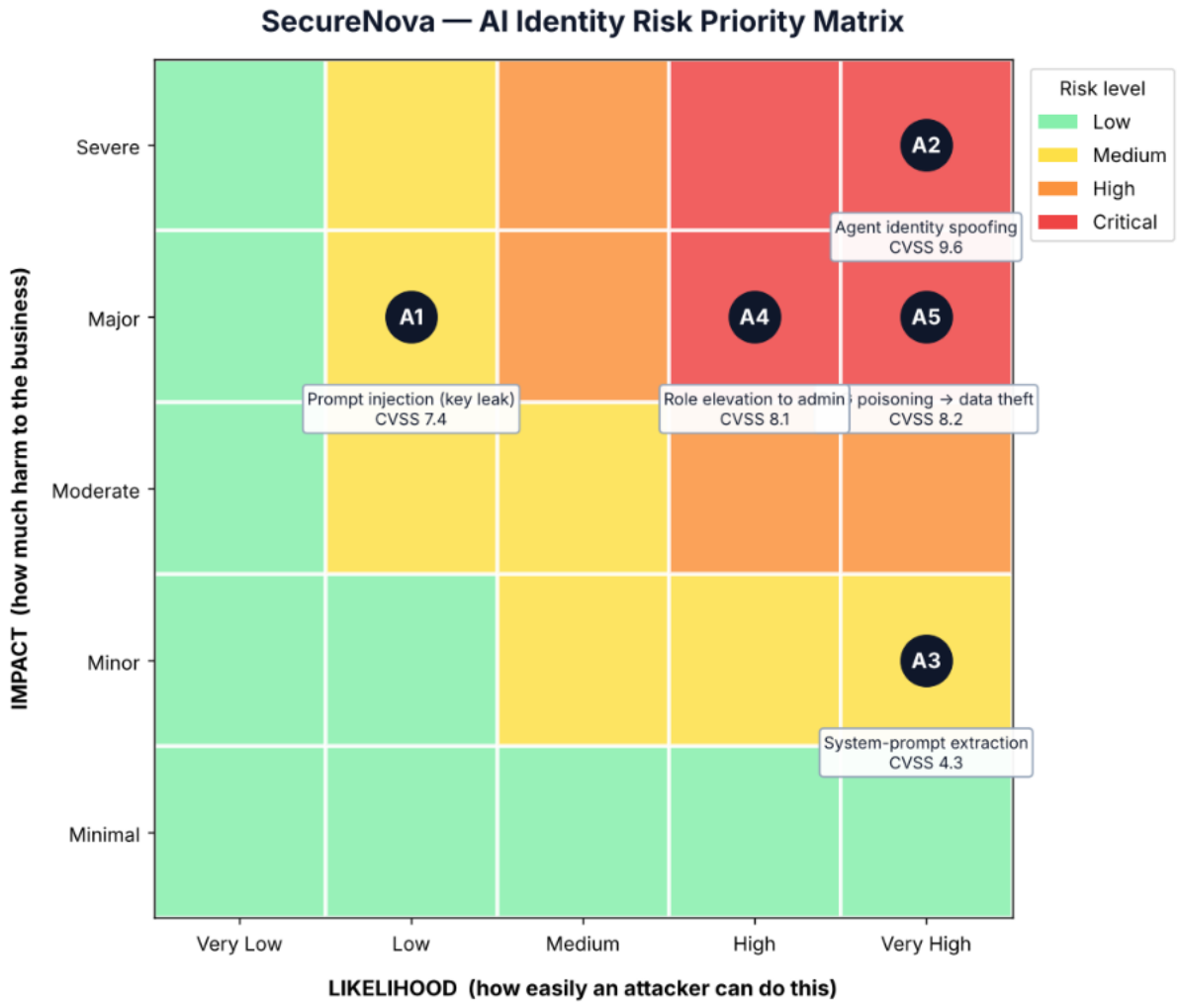


Figure 1 — Risk Priority Matrix. Each bubble is one finding (A1–A5), labelled with its CVSS score (0–10 severity).

Top 5 Recommendations

Ranked by risk reduced per unit of effort. Effort is a rough build estimate for one engineer.

#	Recommendation	Effort	Business rationale
1	Enforce signed agent identity (Ed25519) + server-side scope checks on every privileged action	**Medium — 2–3 weeks**	Closes the most severe finding (A2, CVSS 9.6). Without it, an attacker could impersonate an agent and gain admin access to customer data — a reportable breach. This is the single highest-value fix.
2	Run the input + output guardrails in production (currently validated, not yet live everywhere)	**Medium — 2 weeks**	Stops prompt injection and data exfiltration (A1, A4, A5) — the most common real-world attacks on AI assistants. Directly protects customer PII and the SecureNova brand; blocked 13/13 test attacks.
3	Automate secret scanning and 90-day key rotation in the build pipeline	**Low — about 1 week**	Cheapest fix with high return. During the project a credential was briefly exposed; automated scanning prevents leaked keys reaching code or screenshots, cutting account-takeover risk. Satisfies the credential-governance policy.

4	Stream agent and Auth0 logs to a monitoring system (SIEM) with real-time alerts and on-call paging	**Medium–High — 3–4 weeks**	Our anomaly detection works but runs offline. Real-time alerting shrinks the time an attacker stays undetected from days to minutes, and is expected by the NIST AI risk framework (Manage function).
5	Stand up a continuous red-team / evaluation pipeline for the assistant	**Medium — ongoing**	Today's guardrails were tuned to known attacks. New phrasings will appear. Continuous automated testing catches novel attacks before adversaries do, keeping protection current as the threat landscape evolves.